

STEP 5 — Authentication (Output)

Deliverable ຂອງ STEP 5 ຕາມ Book 3 (Prompt) + Book 2 Phase 5. ສ້າງອີງ Book 1: §12, §13, §14, §54. ຂຽນ src/Auth.gs (+ ອັບເດດ Code.gs, i18n). ຄອບຄຸມ: OAuth/Session, RBAC, Route Guard (frontend+backend), Permission Matrix, Audit (Login/Logout/Denied), 3 ພາສາ.

△ STEP 4 Approved (99.7/100). ໃນ GAS Web App, Google ຈັດການ OAuth ໃຫ້ແລ້ວ — Auth.gs ຈັບຄູ່ email ກັບ Sheet Users → Role.

1. OAuth & Session Management

- OAuth: GAS Web App ໃຊ້ Google Login ອັດຕະໂນມັດ; server ຮູ້ຕົວຕົນຜ່ານ Session.getActiveUser().getEmail() (§13).
- getCurrentUser(): ຈັບຄູ່ email → Sheet Users; ຄືນ null ຖ້າບໍ່ມີ ຫຼື Active=false.
- login(meta): ກວດ identity → ສ້າງ session token (Utilities.getUuid) ເກັບໃນ CacheService TTL 6 ຊມ. → audit LOGIN.
- getSession(token) / logout(token): ອ່ານ/ລຶບ session; logout → audit LOGOUT.
- ຫ້າມເກັບ password (OAuth-only, §13). token ບໍ່ຜູກຂັ້ນມູນ sensitive.

2. Role-Based Access Control (RBAC)

3 Role ຕາມ §13.1. can(user, module, action) ກວດຈາກ Permission Matrix; Admin ໄດ້ທຸກຢ່າງ (*).

3. Permission Matrix

Module	Admin	Editor	Viewer
Dashboard	ທັງໝົດ	view	view
Photos	ທັງໝົດ	view/create/edit	view
Orders	ທັງໝົດ	view/create/edit/print	view
Documents	ທັງໝົດ	view/create/edit	view
Search	ທັງໝົດ	view	view
Reports	ທັງໝົດ	view	✗
Settings	ທັງໝົດ	✗	✗
Users	ທັງໝົດ	✗	✗

4. Route Guard (Frontend + Backend)

Backend Guard (ບັງຄັບ)

- `guard(token, module, action, meta)`: ກວດ session + `can()`; ຄືນ user ຖ້າຜ່ານ, throw E005 + `audit PERMISSION_DENIED` ຖ້າບໍ່ຜ່ານ, throw E001 ຖ້າ session ໝົດ.
- ທຸກ API ຝັ່ງ server ຜ່ານ `guard()` ກ່ອນ — ຕົວຢ່າງໃນ `Code.gs`: `api(req) → ROUTES[action] → guard → handler`.

Frontend Guard (support)

- `getUiPermissions(token)`: ຄືນ `{role, modules:{module:[actions]}}` ໃຫ້ client ຊ່ອນ/ສະແດງເມນູ ແລະ guard route (Phase 7/8).

△ Frontend guard ເປັນ UX ເທົ່ານັ້ນ — ຄວາມປອດໄພຈິງບັງຄັບຢູ່ Backend `guard()` ສະເໝີ (§13).

5. Audit (Login / Logout / Permission Denied)

EventType	ເມື່ອໃດ
LOGIN	login ສໍາເລັດ
LOGIN_FAILED	email ບໍ່ມີໃນ Users / ບໍ່ active (E001)
LOGOUT	logout
PERMISSION_DENIED	guard ບໍ່ຜ່ານ (E005) — ບັນທຶກ module/action

△ `audit()` ບັນທຶກ AuditLogs ຜ່ານ IP/Browser/Device (ຈາກ meta, STEP 3.1) — §12, §52.

6. Multi-language (Auth messages)

ເພີ່ມ key `auth.*` ແລະ `error.E006/E007` ໃນ `i18n/lo|th|en.json` (§14): `auth.login`, `auth.logout`, `auth.login.success`, `auth.denied`. `tAuth(key, meta)` ໃຊ້ fallback ຂັ້ນຕໍ່າ (Phase 6 ຈະຕໍ່ກັບ `t()` ຈິງ).

7. Deliverables & Acceptance (STEP 5)

Deliverables

- `Auth.gs` (OAuth/session, RBAC, guard, `getUiPermissions`)
- Permission Matrix (8 module × 3 role)
- Backend + Frontend Route Guard
- Audit: LOGIN/LOGOUT/PERMISSION_DENIED
- `Code.gs` router (`api` + `ROUTES`) ໃຊ້ guard
- Auth i18n keys (3 ພາສາ)

Acceptance (§25 + Phase 5)

- ຜູ້ບໍ່ມີສິດເຂົ້າ Feature ບໍ່ໄດ້ → E005 ✓
- ບໍ່ log/ເກັບ password (OAuth-only) ✓
- ທຸກ Login/Logout/Denied ບັນທຶກ AuditLog ✓
- Backend guard ບັງຄັບທຸກ API ✓

8. ສະຫຼຸບ (Code Review) & ວິທີທົດສອບ

ໄຟລ໌ທີ່ເພີ່ມ/ແກ້: src/Auth.gs (ໃໝ່), src/Code.gs (router+guard), i18n/lo|th|en.json (auth keys). Syntax ຜ່ານ node --check; JSON ຖືກຕ້ອງ.

ວິທີທົດສອບ (ໃນ **GAS**): (1) seedDatabase ໃຫ້ມີ Admin. (2) login() → ໄດ້ token. (3) guard(token,"settings","view") ດ້ວຍ Editor → ຄາດ E005 + AuditLog PERMISSION_DENIED. (4) getUiPermissions(token) ກວດ menu ຕໍ່ role. (5) logout → session ຫາຍ.

ຂັ້ນຕໍ່ໄປ: ຫຼັງ Accept STEP 5 → STEP 6 (Multi-language) — helper t(key) + ຕົວສະຫຼັບພາສາ.